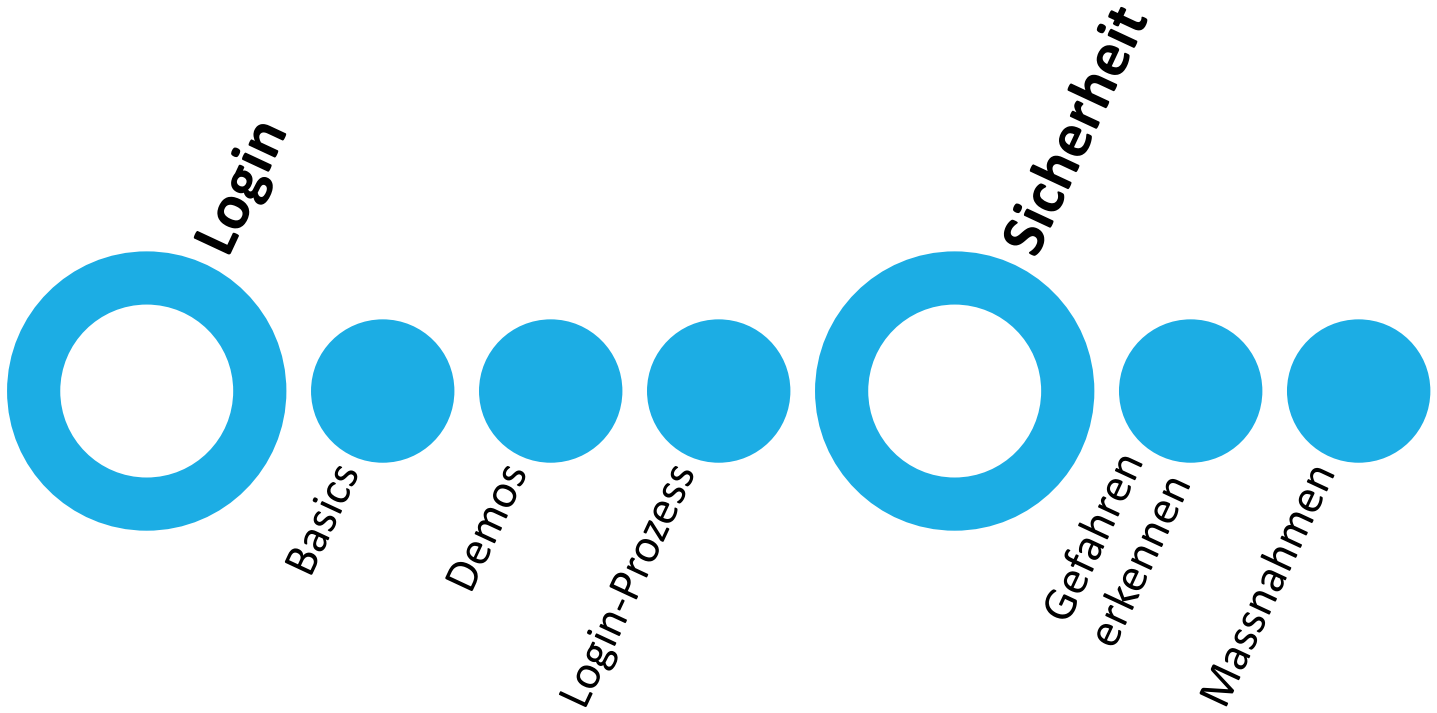
Programm diese Woche



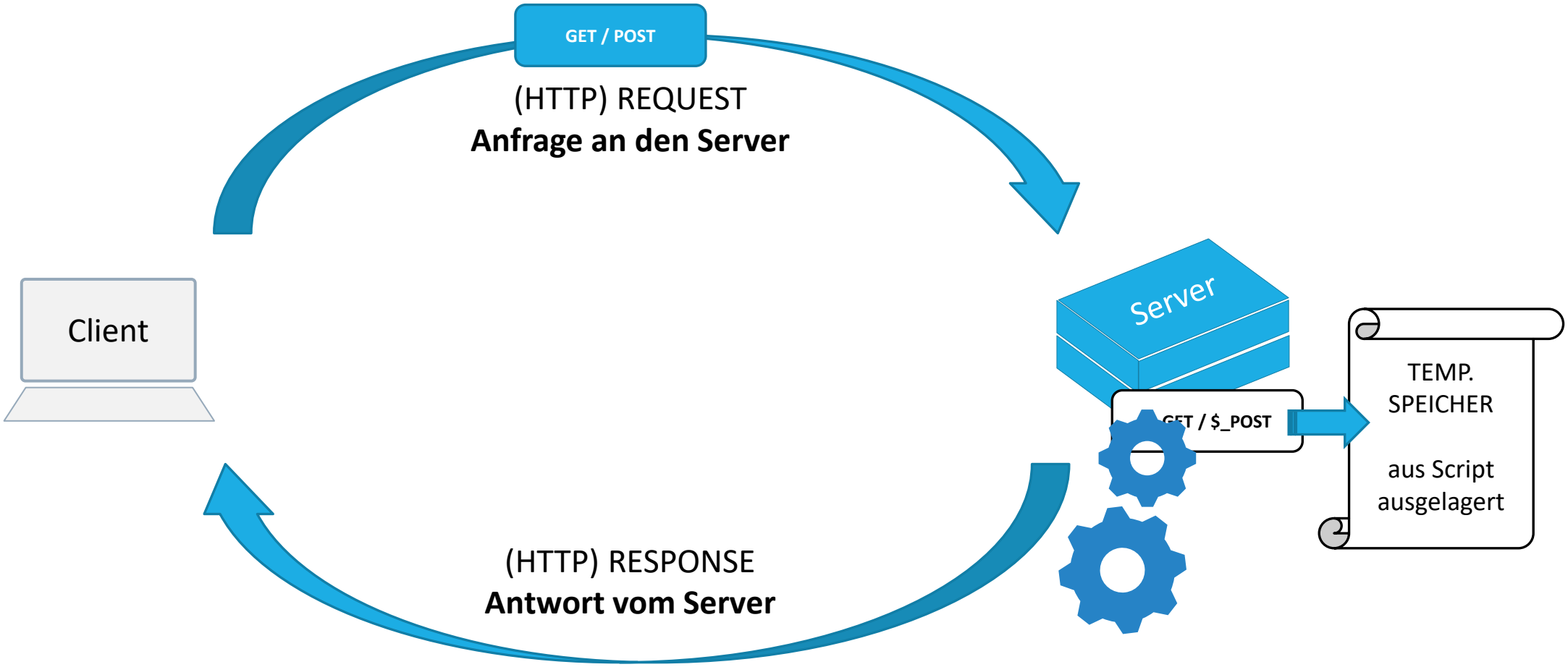
Kompetenz

«einen sicheren, passwortgeschützten Bereich mit Login aufbauen unter Berücksichtigung der spezifischen Gefahren»

- Sessions und Cookies für temporäre Datenspeicherung nutzen
- Passworte sicher ablegen
- Gefahren durch Sessions und Cookies kennen
- Geeignete Massnahmen anwenden, um Gefahren durch User Input zu minimieren

© 2017 BY TERRY HARKER / TERRY@BYTEKULTUR.NET

Der Server / Client Kreislauf



CLIENT	SERVER

Labor Übung

Zeit: 10min

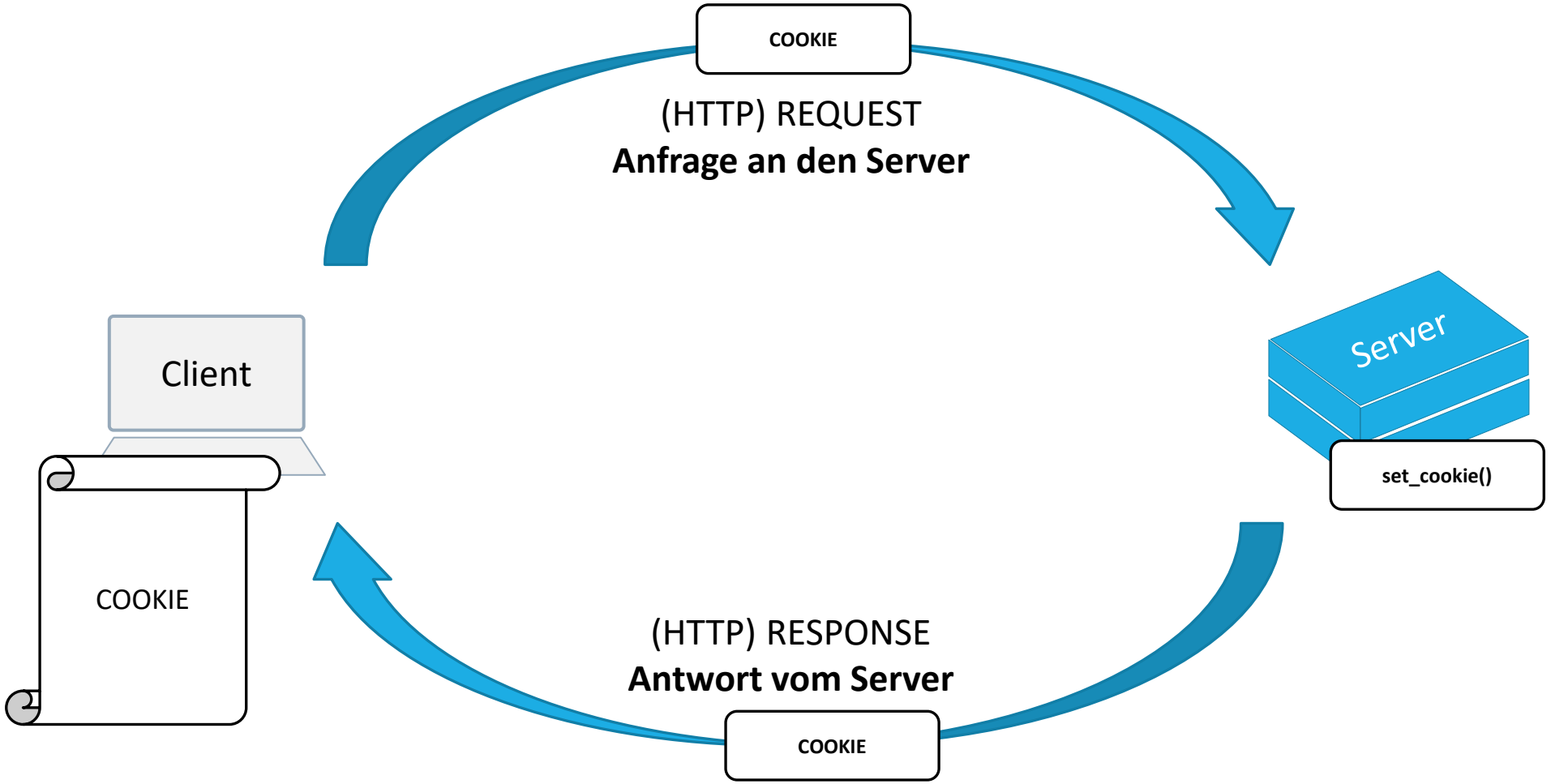
Beobachte die Cookies mit einem Cookie Manger

Nutze (installiere) dafür ein Cookie Browser-AddOn (z.B. für Chrome: «CookieManager»)

- wann sind sie da, wann nicht mehr?
- Woran erkennt man, ob eine Session existiert?

© 2017 BY TERRY HARKER / TERRY@BYTEKULTUR.NET

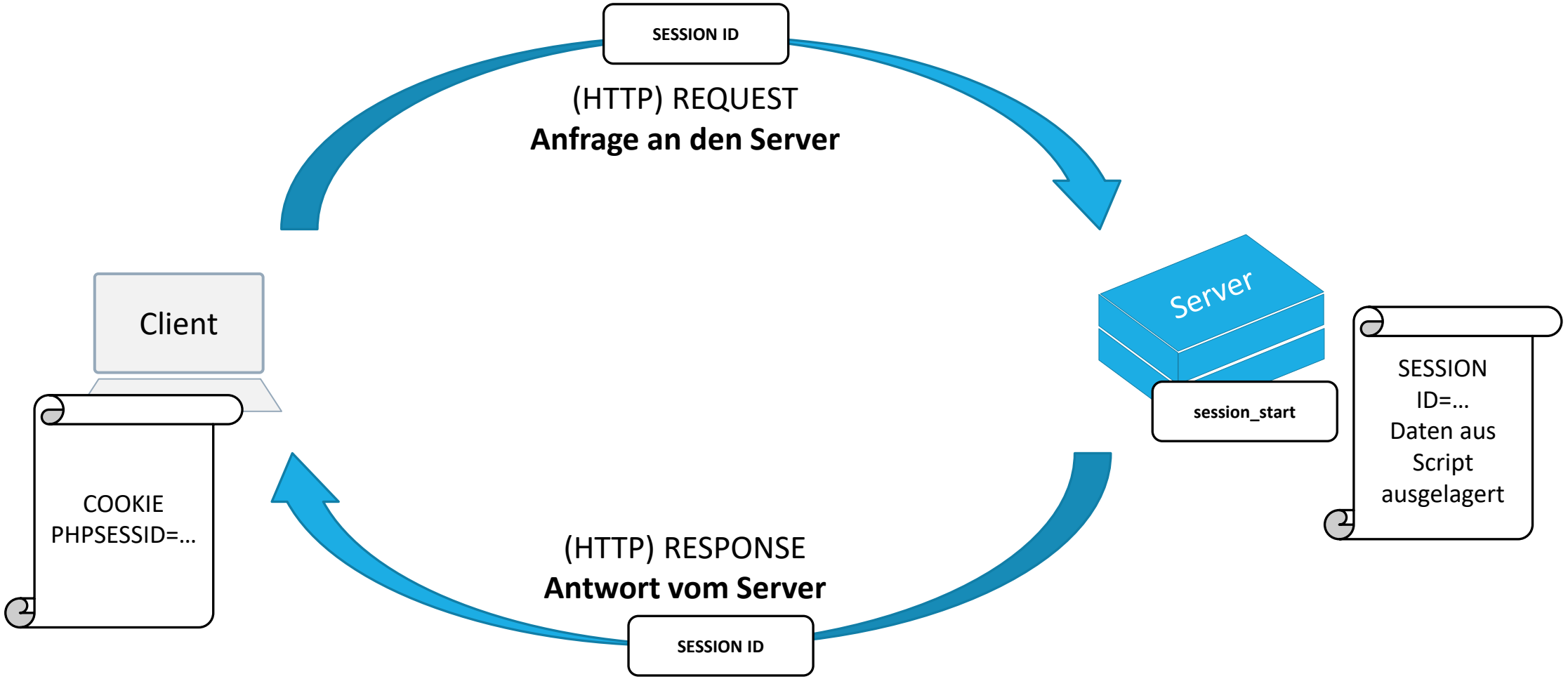
Cookie im Server-Client Kontext



CLIENT: cookie

SERVER: session

Session im Server-Client Kontext



CLIENT: cookie

SERVER: session

Anwendung: Cookies

Typische Anwendungen für Cookies:

- **Cookie Consent Manager**: im Cookie wird gespeichert, ob der Besucher Cookies erlaubt ☺
- **Settings/Präferenzen merken**: Cookie merkt sich Einstellungen wie Sprache, Region oder gewählte Filter
- **Tracking / Analytics**: Tracking-Dienste nutzen Cookies, um zwischen verschiedenen Besuchern unterscheiden und wiederkehrende Besucher erkennen zu können
- **Warenkorb**: Produkt-ID's und Anzahl aller Produkte des Warenkorbs für beliebig lange Zeit in einem Cookie speichern (z.B. als JSON-String)

 © 2017 BY TERRY HARKER / TERRY@BYTEKULTUR.NET

Anwendung: Sessions

Typische Anwendungen für Sessions:

- **Login**: in der Session wird gespeichert, ob der Besucher sich erfolgreich eingeloggt hat ☺
- **Warenkorb**: Session enthält alle ID's und Mengen der Produkte im Warenkorb
- **Formular-Schutz / CSRF Token**: Session enthält einen Hash, der im Formular mitgeschickt und mit dem Sessionwert verglichen wird (Herkunftsprüfung der Daten)
- **Multipage Formulare**: auf jeder «Seite» wird ein Teil-Formular ausgefüllt und die Daten in der Session gesammelt.
- **Bild-Captcha**: ein String aus Zahlen und Buchstaben wird in der Session gespeichert und in einem Bild ausgegeben, das der Besucher lesen/abschreiben können muss